

OT/ICS SECURITY ASSESSMENT REPORT

Water Treatment Infrastructure | Modbus TCP Vulnerability Analysis

Client / Asset: Municipal Water Booster Station (Simulated Lab Environment)

Assessor: Deepak Varma

Assessor Background: 9+ years operations and process safety at Reliance Industries and Tata Steel

Assessment Type: OT Vulnerability Assessment, Penetration Test, and Remediation Verification

Assessment Date: July 2026

Report Version: 1.0

Report Status: Final

Frameworks Applied: IEC 62443, MITRE ATT&CK for ICS, Purdue Reference Model, NIST SP 800-82

Applicable Legislation: Australian Security of Critical Infrastructure Act 2018 (SOCIA Act)

This report was produced as part of an OT/ICS security portfolio project. The assessment was conducted in a controlled lab environment using simulated industrial equipment. All attack techniques demonstrated are for educational purposes only and must not be reproduced against production systems without explicit written authorisation.

Table of Contents

1. Executive Summary	3
2. Scope and Objectives	5
2.1 Objectives	5
2.2 Assessment Period and Timeline	5
2.3 Rules of Engagement	5
2.4 Reference Architecture and Purdue Model	6
2.5 Scope	6
2.6 Out of Scope	7
2.7 Threat Actors Considered	7
2.8 Testing Limitations	7
2.9 Regulatory Context - SOCI Act 2018	8
3. Asset Inventory	9
4. Methodology and Risk Scoring	10
4.1 Assessment Methodology	10
4.2 Tools Used	10
4.3 Risk Scoring	10
4.4 IEC 62443 Framework Mapping	11
5. Detailed Findings	13
5.1 Finding 1 - Unauthenticated Read Access to Process Data	13
5.2 Finding 2 - Unauthenticated Write Access to Process Control	14
5.3 IEC 62443 Gap Analysis	15
6. Risk Register	16
7. Mitigations Implemented	17
7.1 Control 1 - IP Allowlist Firewall	17
7.2 Control 2 - Modbus Function Code Filter	18
7.3 Control 3 - Audit Logging	18
8. Remediation Roadmap and Retest Results	19
9. Conclusion	21

1. Executive Summary

Background

In November 2023, the Municipal Water Authority of Aliquippa in Pennsylvania became one of the most documented victims of an operational technology cyberattack when the Iranian Government-affiliated threat group CyberAv3ngers gained direct control of a Unitronics programmable logic controller managing water pressure to residential areas. The attackers exploited the complete absence of authentication on the Modbus industrial protocol to read live process data and issue control commands remotely, without any credentials. The incident triggered a joint advisory from CISA, FBI, NSA, and EPA and demonstrated that water treatment infrastructure across the United States and allied nations remains exposed to this class of vulnerability.

The Modbus protocol was developed in 1979 for serial communication between industrial devices on physically isolated private networks. Security was not a design consideration because the protocol was never intended to be reachable from outside the plant floor. Over the following four decades, Modbus became the dominant industrial communication protocol worldwide due to its simplicity, low licensing cost, and compatibility across every major PLC and SCADA vendor. Today it is estimated that tens of millions of industrial devices communicate using Modbus globally, spanning water treatment, power generation, oil and gas, manufacturing, and transport infrastructure. Replacing the protocol requires hardware upgrades, firmware changes, and full revalidation of control systems, making wholesale replacement impractical for most asset owners in the short to medium term. This is why compensating controls such as network segmentation, protocol-aware filtering, and comprehensive logging remain the primary security approach in Modbus-enabled environments.

Assessment Purpose

This assessment was conducted to reproduce the Aliquippa attack methodology in a controlled lab environment, demonstrate the vulnerability with technical evidence, implement layered compensating controls aligned to IEC 62443, verify those controls are effective, and produce a structured assessment report following industry reporting standards. The assessment followed the Find, Fix, and Verify methodology used in real OT security engagements.

Key Finding

Modbus TCP has no built-in authentication. Any device that can reach port 502 can read all process variable values and send arbitrary write commands to the PLC without any credentials. This includes stopping pumps, disabling chlorination, and manipulating pipeline pressure. The attack was demonstrated in a simulated water booster station environment and confirmed to be effective within seconds of gaining network access.

Assessment Outcome Summary

Stage	Description	Outcome
Finding 1	Unauthenticated read of all PLC process variables	Critical
Finding 2	Unauthenticated write to pump and chlorination coils	Critical
Control 1 - IP Allowlist Firewall	Restricts port 502 access to authorised SCADA only	Effective
Control 2 - Modbus Function Code Filter	Blocks write commands from non-authorised sources	Effective
Control 3 - Audit Logging	Records all blocked connection attempts with timestamp	Effective
Retest	All attack scenarios blocked after controls applied	Passed
Operational Continuity	Authorised SCADA HMI continued operating throughout	Maintained

2. Scope and Objectives

2.1 Objectives

The objectives of this assessment were to:

- Demonstrate that Modbus TCP provides no authentication or encryption on industrial process data in its default configuration
- Reproduce the attack chain used in the 2023 CyberAv3ngers water treatment incident
- Implement and verify IEC 62443-aligned compensating controls that reduce the risk to an acceptable level
- Confirm that security controls do not disrupt legitimate SCADA operations
- Produce a structured assessment report that could serve as a template for a real OT security engagement

2.2 Assessment Period and Timeline

Phase	Activity	Duration
Phase 1	Environment setup - OpenPLC, Scada-LTS, Docker configuration	2 hours
Phase 2	Passive reconnaissance - Wireshark traffic capture and analysis	1 hour
Phase 3	Active vulnerability testing - Python exploit scripts	2 hours
Phase 4	Attack demonstration and evidence capture	1 hour
Phase 5	Controls implementation - iptables firewall, proxy, logging	2 hours
Phase 6	Retest and verification	1 hour
Phase 7	Report writing and documentation	3 hours
Total		12 hours

2.3 Rules of Engagement

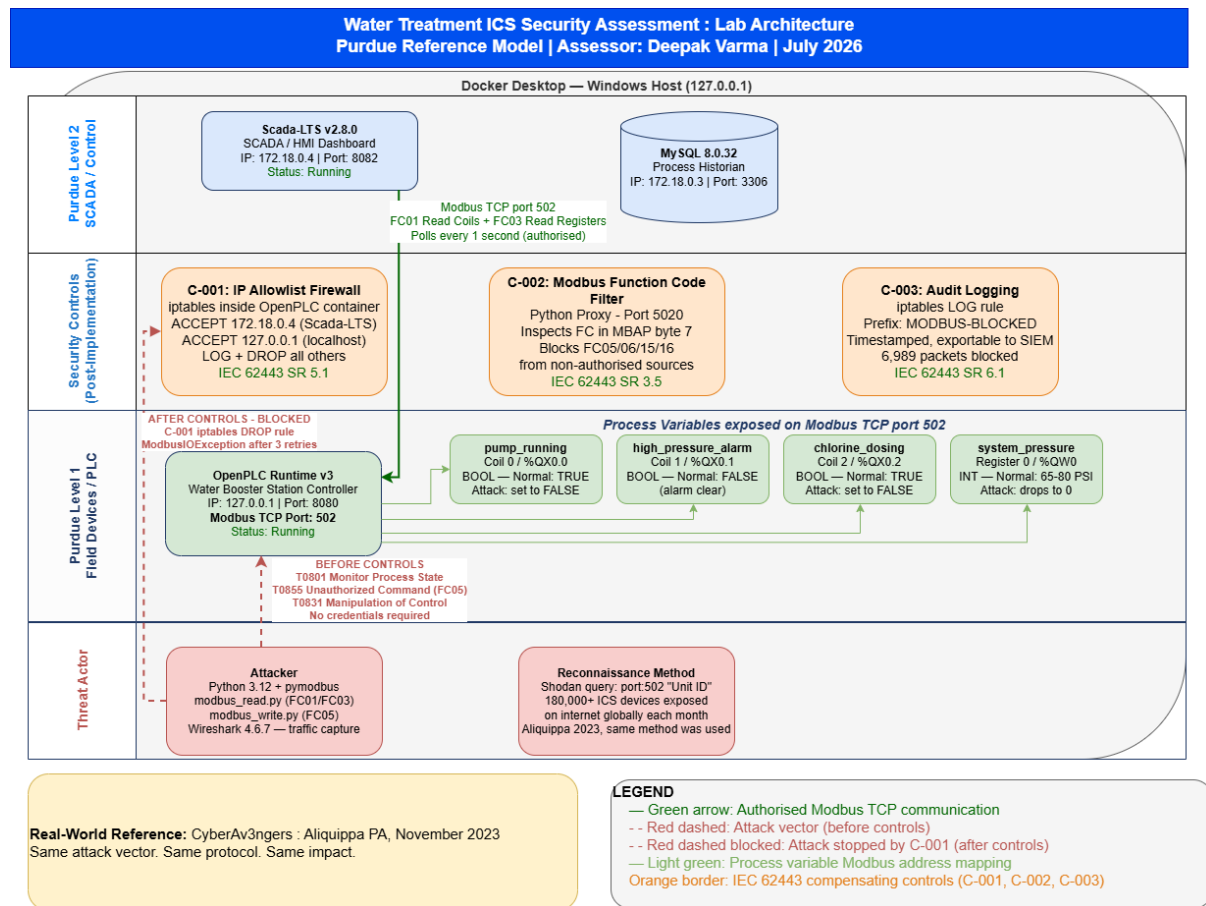
The following rules governed the conduct of this assessment:

- All testing was conducted exclusively against the defined lab environment. No production systems, external networks, or third-party infrastructure were accessed at any point.
- All vulnerability demonstrations were conducted with full knowledge and authorisation of the environment owner.
- No denial of service techniques were used. All testing was designed to demonstrate vulnerabilities without causing lasting damage to the simulated environment.
- All findings were documented with supporting evidence before any compensating controls were applied, to ensure the before state could be clearly demonstrated.
- Exploit scripts were written specifically for this assessment and are not shared publicly.

2.4 Reference Architecture and Purdue Model

This assessment uses the Purdue Reference Model, also known as the ISA-95 model, as the architectural framework for classifying assets and defining security boundaries. The Purdue Model divides industrial environments into five levels, from physical field devices and sensors at Level 0 through to enterprise business systems at Level 4 and 5. Security controls are applied at the boundaries between levels to restrict communication to only what is operationally required.

The lab environment simulates Levels 1 and 2, which represent the most common attack surface in water treatment infrastructure. The diagram below maps the assessment components to their respective Purdue levels.



2.5 Scope

Component	Description	In Scope
OpenPLC Runtime v3	Simulated water booster station PLC running in Docker	Yes
Scada-LTS v2.8.0	SCADA and HMI operator dashboard running in Docker	Yes
MySQL Database	Scada-LTS process historian database	Yes
Modbus TCP port 502	Primary industrial communication protocol	Yes
Python exploit scripts	Custom scripts using pymodbus library	Yes
Wireshark 4.6.7	Network traffic capture and Modbus protocol analysis	Yes
iptables firewall	Host-based firewall inside OpenPLC container	Yes
Modbus proxy	Custom Python function code filter on port 5020	Yes

2.6 Out of Scope

Item	Reason
Physical security controls	Not applicable in lab environment
Wireless network interfaces	Not present in lab architecture
Remote access infrastructure (VPN, RDP)	Not configured in lab environment
Vendor and third-party access paths	Not applicable in lab environment

Item	Reason
Corporate IT network	Not present in lab architecture
PLC firmware and hardware integrity	Requires physical hardware access
Personnel security and insider threat	Out of scope for technical assessment
Supply chain risks	Out of scope for this engagement
Internet-facing interfaces	No internet exposure in lab environment

2.7 Threat Actors Considered

This assessment considered three threat actor profiles relevant to water treatment infrastructure:

Threat Actor	Motivation	Capability	Relevance to This Assessment
Nation-state actor (e.g. CyberAv3n9ers)	Geopolitical disruption, infrastructure damage	High - well-resourced, patient, OT-specific knowledge	Directly relevant. The Aliquippa 2023 attack by IRGC-affiliated actors demonstrates this threat is active against water infrastructure.
Hacktivist	Political or environmental causes, public attention	Medium - opportunistic, targets exposed systems	Relevant. Water treatment is a high-visibility target. Shodan exposure of port 502 would attract hacktivist attention.
Insider threat	Grievance, financial gain, coercion	Low to high - depends on access level	High risk in real environments. Bypasses all perimeter controls. Not demonstrated in this lab but noted as a residual risk.

2.8 Testing Limitations

The following limitations apply to the findings and conclusions in this report:

- The lab environment uses Docker containers which may behave differently to physical PLC hardware in some edge cases. Findings are representative of the protocol vulnerability but may not capture all hardware-specific behaviours.
- The assessment tested a single Modbus TCP communication path. Real water treatment environments typically have multiple PLCs, remote terminal units, and communication paths, each of which would require individual assessment.
- Firmware integrity of the PLC was not assessed. Attackers with firmware modification capability could persist beyond network-level controls.
- The assessment did not evaluate the response capability of the operations team. A real engagement would include tabletop exercises to test incident detection and response procedures.
- Wireless interfaces, physical access controls, and supply chain risks were not assessed and represent residual risk outside the scope of this engagement.

2.9 Regulatory Context - SOCI Act 2018

Overview

The Security of Critical Infrastructure Act 2018 (SOCI Act) is Australian Commonwealth legislation that establishes mandatory security obligations for owners and operators of critical infrastructure assets. Water and sewerage systems are declared critical infrastructure under Schedule 2 of the SOCI Act. This means operators of water treatment facilities that meet the threshold criteria have legally enforceable obligations governing how their OT systems must be designed, monitored, and reported on.

Asset Registration

Under Part 2 of the SOCI Act, the operator of a water treatment facility must register the asset with the Cyber and Infrastructure Security Centre (CISC) via the CIRMP portal at cisc.gov.au. Registration requires identifying the responsible entity, the asset type, and any direct interests held in the asset.

Critical Infrastructure Risk Management Programme

Under Part 2A of the SOCI Act, registered critical infrastructure asset owners must maintain a Critical Infrastructure Risk Management Programme (CIRMP). The CIRMP must address four mandatory hazard categories:

Hazard Category	Relevance to This Assessment
Cyber hazards	The vulnerabilities identified in this report constitute a cyber hazard that must be addressed in the CIRMP. Specifically, unauthenticated Modbus access represents an unacceptable risk under any reasonable CIRMP framework.
Personnel hazards	Insider threat via authorised network access is a residual risk not addressed by the network-level controls implemented in this assessment. Personnel vetting and access management controls are required.
Supply chain hazards	PLC firmware integrity and vendor remote access controls are supply chain risks. These were noted as out of scope for this engagement but must be addressed in the CIRMP.
Physical hazards	Physical access to the PLC panel bypasses all network-level controls. Physical security measures including access control, CCTV, and tamper detection are required.

The CIRMP must be reviewed and approved by the board of the responsible entity on an annual basis.

Incident Reporting Obligations

Under sections 30BC and 30BD of the SOCI Act, operators must report cyber incidents to the Australian Signals Directorate (ASD) within the following timeframes:

Incident Type	Definition	Reporting Timeframe
Critical cyber incident	A cyber incident that has had, is having, or is likely to have a significant impact on the availability of the critical infrastructure asset	12 hours from the time the responsible entity becomes aware
Cyber incident	A cyber incident that has had, is having, or is likely to have an impact on the asset	72 hours from the time the responsible entity becomes aware

The attack demonstrated in this report, specifically stopping the booster pump and disabling chlorination, would constitute a critical cyber incident under the SOCI Act because it directly impacted the availability of the water treatment asset. Under the 12-hour reporting obligation, the responsible entity would need to notify ASD within 12 hours of becoming aware of the incident. This has a direct design implication: the security monitoring and logging infrastructure must be accessible to the security team without requiring them to access the OT network, particularly during an active incident where OT systems may be compromised.

SOCI Act Compliance Status

SOCI Act Obligation	Status in Assessment	Gap
Asset registered with CISC	Not applicable - simulated environment	N/A
CIRMP maintained covering cyber hazards	Partially addressed by this assessment	Personnel, physical, and supply chain hazards not covered
Cyber hazard identified and documented	Addressed - Findings F-001 and F-002	None
Compensating controls implemented	Addressed - Controls C-001, C-002, C-003	Protocol-level authentication not yet implemented
Incident detection capability	Partially addressed - iptables logging in place	No SIEM integration or real-time alerting
12-hour ASD reporting capability	Not demonstrated in lab environment	Requires SIEM in DMZ in production deployment
Annual CIRMP review	Not applicable - portfolio project	N/A

3. Asset Inventory

The following table documents all assets identified and assessed during this engagement. In a real OT security assessment, asset discovery would precede all other phases because security decisions cannot be made without a complete picture of what exists on the network. In this lab environment, all assets were known at the outset.

Asset ID	Asset Name	Type	Vendor / Version	IP Address	Port	Purdue Level	Criticality
A-001	OpenPLC Runtime	PLC	tuttas/openplc_v3	127.0.0.1	502, 8080	Level 1	Critical
A-002	Scada-LTS	SCADA / HMI	scadalts v2.8.0	172.18.0.4	8082	Level 2	High
A-003	MySQL Database	Historian DB	mysql/mysql-server 8.0.32	172.18.0.3	3306	Level 2	Medium
A-004	HiveMQ Broker	MQTT Broker	hivemq/hivemq4	172.18.0.5	1883	Level 2	Low
A-005	Modbus Proxy	Security Control	Custom Python 3.12	127.0.0.1	5020	L1/L2 boundary	High
A-006	Docker Host	Container Platform	Docker Desktop v4.83	127.0.0.1	N/A	Infrastructure	High

Asset Criticality Definitions

Criticality	Definition
Critical	Compromise or loss of availability directly impacts water treatment operations or public safety
High	Compromise enables lateral movement to critical assets or reduces operator visibility of the process
Medium	Compromise affects data integrity or historical records but does not directly impact operations
Low	Compromise has limited operational impact

Process Variables Monitored

The OpenPLC water booster station program exposes four process variables on Modbus TCP. These are the specific data points that were read and written during the vulnerability demonstration:

Variable Name	Type	Modbus Address	Normal Value	Impact if Attacked
pump_running	BOOL Coil	%QX0.0 / Coil 0	TRUE	Water supply loss to elevated residential areas
high_pressure_alarm	BOOL Coil	%QX0.1 / Coil 1	FALSE (alarm clear)	Safety alarm masked from SCADA operators
chlorine_dosing	BOOL Coil	%QX0.2 / Coil 2	TRUE	Untreated water enters the distribution network
system_pressure	INT Register	%QW0 / Register 0	65 to 80 PSI	Over-pressurisation or pressure loss risk

4. Methodology and Risk Scoring

4.1 Assessment Methodology

The assessment followed a structured three-stage methodology:

Stage 1 - Find: Identify vulnerabilities through passive observation using Wireshark traffic capture and active testing using Python exploit scripts. Capture technical evidence for each finding before any remediation is applied.

Stage 2 - Fix: Implement compensating controls aligned to IEC 62443 security requirements. Document each control with configuration evidence and confirm it does not disrupt authorised operations.

Stage 3 - Verify: Retest all attack scenarios after controls are applied. Confirm controls are effective and that the authorised SCADA connection remains operational.

4.2 Tools Used

Tool	Version	Purpose
OpenPLC Runtime	v3 (Docker)	Simulated PLC running the water booster station program
Scada-LTS	v2.8.0 (Docker)	SCADA and HMI operator dashboard and process historian
Wireshark	4.6.7	Network packet capture and Modbus protocol analysis
Python	3.12	Custom attack scripts and Modbus proxy implementation
pymodbus	Latest stable	Python Modbus TCP client library used in exploit scripts
Docker Desktop	v4.83	Container platform running OpenPLC and Scada-LTS
iptables	Bundled with container OS	Host-based firewall applied inside OpenPLC container

4.3 Risk Scoring

All findings are rated using the Common Vulnerability Scoring System version 3.1 (CVSS v3.1). The following rating scale is applied throughout this report:

Rating	CVSS Score Range	Response Timeframe
Critical	9.0 to 10.0	Immediate remediation required. Treat as active incident.
High	7.0 to 8.9	Remediate within 7 days. Interim controls required immediately.
Medium	4.0 to 6.9	Remediate within 30 days. Monitor for exploitation.
Low	0.1 to 3.9	Remediate within 90 days. Review at next scheduled maintenance.

4.4 IEC 62443 Framework Mapping

Overview of IEC 62443

IEC 62443 is a series of international standards developed by the International Society of Automation (ISA) that defines requirements for securing industrial automation and control systems. It is the primary OT security standard referenced by regulators, asset owners, and security vendors worldwide. Unlike IT security frameworks such as ISO 27001, IEC 62443 is specifically designed for environments where availability and process safety take precedence over confidentiality, and where patching cycles are measured in years rather than days.

Standard Part	Title	Relevance to This Assessment
IEC 62443-1	General concepts and terminology	Defines zones, conduits, and security levels used throughout this report
IEC 62443-2	Policies and procedures	Informs CIRMP alignment and patch management recommendations
IEC 62443-3	System requirements	Zone and conduit design, security level targeting, SR requirements assessed
IEC 62443-4	Component requirements	PLC and SCADA product-level security requirements

Security Levels

IEC 62443 defines four Security Levels (SL) that describe the capability of the attacker that a zone is designed to resist:

Security Level	Attacker Profile	Applicable Zone in This Assessment
SL 1	Casual or unintentional violation	Not applicable - all zones require at minimum SL 2
SL 2	Intentional attack with moderate resources and OT knowledge	SCADA Zone (Level 2) - Target SL 2
SL 3	Sophisticated, well-resourced attacker with OT-specific capability	PLC Zone (Level 1) - Target SL 2 minimum, SL 3 for chlorination control
SL 4	Nation-state level, highly sophisticated targeted attack	Not targeted in this lab environment

Security Requirements Assessed

The following IEC 62443-3-3 system-level security requirements were evaluated:

SR Reference	Requirement	Before Assessment	Control Applied	After Assessment
SR 1.1	Human User Identification and Authentication	No authentication on Modbus TCP. Any device connects without credentials.	C-001 restricts access by source IP as a compensating control.	Partially met. IP allowlist provides access control but not authentication.
SR 1.2	Software Process and Device Authentication	No device authentication. OpenPLC accepts connections from any device.	C-001 and C-002 together restrict access by IP and function code.	Partially met. Device identity is not verified at the protocol level.
SR 3.5	Input Validation	All Modbus function codes accepted from any source. Write commands executed immediately.	C-002 (Modbus proxy) inspects every function code and blocks writes from non-authorised sources.	Met. Write function codes blocked from all sources except authorised HMI.
SR 4.1	Information Confidentiality	All Modbus traffic transmitted in cleartext. No encryption on any communication path.	Not addressed by current controls. Requires protocol replacement or VPN tunnel.	Not met. Cleartext transmission remains. Listed in remediation roadmap.
SR 5.1	Network Segmentation	Port 502 accessible from any device on the network. No segmentation.	C-001 (iptables allowlist) implements network segmentation for port 502.	Met. Only authorised HMI IP can reach port 502.
SR 6.1	Audit Log Accessibility	No logging of Modbus connection attempts. No forensic trail available.	C-003 (iptables LOG rule) creates a timestamped audit trail of all blocked attempts.	Met. All blocked attempts logged with source IP and timestamp.

Zone and Conduit Analysis

IEC 62443-3-2 requires that every system be divided into security zones, and every communication path between zones be defined as a conduit with explicit protocol controls, directionality, and a security mechanism.

Zone	Assets	Target SL	Before Assessment	After Controls
PLC Zone (Level 1)	OpenPLC Runtime v3	SL 2	Port 502 open to all sources. No access control.	IP allowlist restricts port 502 to Scada-LTS IP 172.18.0.4 only.
SCADA Zone (Level 2)	Scada-LTS, MySQL historian	SL 2	SCADA dashboard accessible on port 8082. Internal comms unencrypted.	No change in this assessment. SCADA zone hardening is a future recommendation.
Conduit - SCADA to PLC	Modbus TCP port 502	SL 2	Bidirectional, unauthenticated, unfiltered. Any source could connect.	IP allowlist (C-001) and function code filter (C-002) applied to this conduit.

5. Detailed Findings

5.1 Finding 1 - Unauthenticated Read Access to Process Data

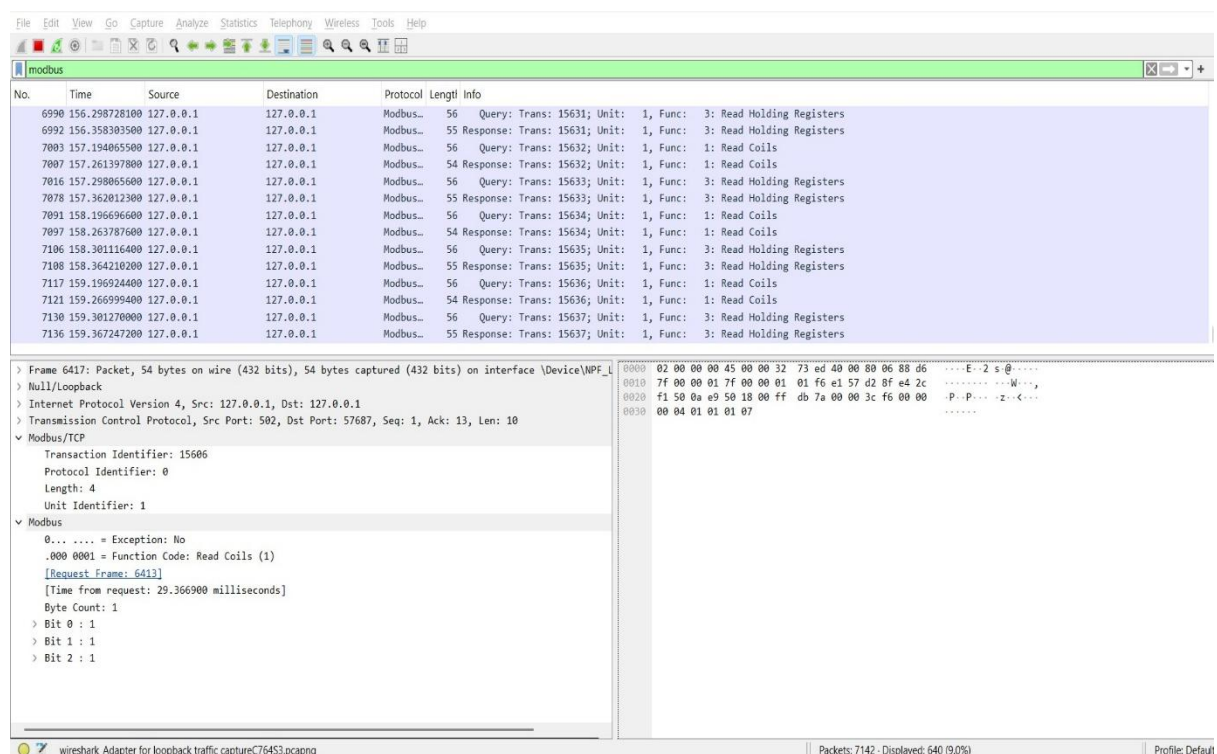
Field	Detail
Finding ID	F-001
Severity	Critical
CVSS v3.1 Score	9.8 (AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H)
Affected Asset	OpenPLC Runtime v3 - port 502 (Modbus TCP)
IEC 62443 Gap	SR 1.1 (Identification and Authentication) SR 4.1 (Information Confidentiality)
MITRE ATT&CK for ICS	T0801 - Monitor Process State

Description

The Modbus TCP protocol does not include any authentication mechanism in its specification. Any device on the network that can reach port 502 can establish a connection and read all process variable values without providing any credentials. All traffic is transmitted in cleartext with no encryption. In practice, this means an attacker with network access can silently collect complete operational intelligence about the water treatment process, including which pumps are running, current pipeline pressure readings, whether safety alarms are active, and whether the chlorination system is operating.

Evidence

Wireshark packet capture confirmed that Modbus TCP traffic is fully visible in cleartext. Function Code 01 (Read Coils) and Function Code 03 (Read Holding Registers) responses contained live process data with no authentication headers or encryption. The Wireshark screenshot below shows the packet contents exposed in plain text.



A Python script using the pymodbus library connected to OpenPLC on port 502 and returned all four process variables with no credentials required:

```
Target : 127.0.0.1:502
Credentials required : NONE
Authentication mechanism : NONE

pump_running      (Coil 0 / %QX0.0) : True
high_pressure_alarm (Coil 1 / %QX0.1) : True
chlorine_dosing    (Coil 2 / %QX0.2) : True
system_pressure    (Reg 0 / %QW0)    : 80 PSI

Read complete. Zero authentication was required.
Any device on this network can see all PLC process values.
```

```
Windows PowerShell
PS C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_read.py
=== OT Security Lab: Unauthenticated Modbus Read ===
Connecting to OpenPLC at 127.0.0.1:502...
No username. No password. No credentials of any kind.

--- Coil Values (Boolean ON/OFF) ---
pump_running      (Coil 0): True
high_pressure_alarm (Coil 1): True
chlorine_dosing    (Coil 2): True

--- Register Values (Integer) ---
system_pressure (Register 0): 80 PSI

=== Read complete. Zero authentication was required. ===
Any device on this network can see all PLC values.
PS C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> |
```

Business Impact

An attacker with network access can monitor all operational data from the water treatment process in real time without any indication that they are doing so. This enables targeted attack planning with full visibility of system state prior to executing disruptive actions. In the Aliquippa 2023 incident, reconnaissance of this type preceded the control manipulation that caused the incident.

5.2 Finding 2 - Unauthenticated Write Access to Critical Process Control

Field	Detail
Finding ID	F-002
Severity	Critical
CVSS v3.1 Score	10.0 (AV:N / AC:L / PR:N / UI:N / S:C / C:H / I:H / A:H)
Affected Asset	OpenPLC Runtime v3 - port 502 (Modbus TCP)
IEC 62443 Gap	SR 3.5 (Input Validation) SR 5.1 (Network Segmentation)
MITRE ATT&CK for ICS	T0855 - Unauthorized Command Message T0831 - Manipulation of Control

Description

Modbus TCP allows any device that can reach port 502 to send write commands directly to the PLC with no authentication, no confirmation, and no access control. Using Modbus Function Code 05 (Write Single Coil), an attacker can set any Boolean process variable to any value. The PLC executes the command immediately and without any verification that the command originated from an authorised source. This includes stopping the booster pump and disabling chlorination, both of which have direct public safety consequences.

Evidence

A Python script sent write commands directly to the PLC. Both commands succeeded without any credentials. The Scada-LTS SCADA dashboard immediately reflected the changed values, confirming the attack was effective.

Target : 127.0.0.1:502
Credentials required : NONE

Values BEFORE attack:

```
pump_running      : True
chlorine_dosing   : True
system_pressure   : 80 PSI
```

Writing False to pump_running (Coil 0) via FC05 ...

Write successful - pump stopped, no authentication required

Writing False to chlorine_dosing (Coil 2) via FC05 ...

Write successful - chlorination disabled, no authentication required

Values AFTER attack:

```
pump_running      : False   (pump stopped)
chlorine_dosing   : False   (chlorination disabled)
system_pressure   : 40 PSI  (pressure dropping)
```

The screenshot displays the Scada-LTS web interface on the left and a Windows PowerShell terminal on the right. The Scada-LTS interface shows a 'Watch list' with five points: 'Water Booster Station - chlorine_dosing', 'Water Booster Station - high_pressure_alarm', 'Water Booster Station - pump_running', 'Water Booster Station - system_pressure', and 'Water Booster Station - chlorine_dosing'. The 'pump_running' and 'chlorine_dosing' points are highlighted in red, indicating they are currently 'False'. The 'system_pressure' point is highlighted in green, indicating it is 'True'.

The PowerShell terminal shows the execution of a Python script named 'modbus_read.py' and 'modbus_write.py'. The script connects to an OpenPLC at 127.0.0.1:502. It reads the current values of the points and then writes 'False' to 'pump_running' and 'chlorine_dosing'. The output shows the values before and after the attack, confirming the successful execution of the attack.

```
PS C:\Users\DV\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_read.py
=== OT Security Lab: Unauthenticated Modbus Read ===
Connecting to OpenPLC at 127.0.0.1:502...
No username. No password. No credentials of any kind.

--- Coil Values (Boolean ON/OFF) ---
pump_running      (Coil 0): True
high_pressure_alarm (Coil 1): True
chlorine_dosing   (Coil 2): True

--- Register Values (Integer) ---
system_pressure (Register 0): 80 PSI

=== Read complete. Zero authentication was required. ===
Any device on this network can see all PLC values.

l security>
PS C:\Users\DV\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_write.py
=== OT Security Lab: Unauthenticated Modbus WRITE ===
Simulating CyberAv3ngers attack on Water Booster Station
Target: OpenPLC at 127.0.0.1:502
Credentials required: NONE

--- Current values BEFORE attack ---
pump_running      : True
high_pressure_alarm : True
chlorine_dosing   : True
system_pressure   : 80 PSI

--- Executing attack ---
Writing FALSE to pump_running (Coil 0)...
Writing FALSE to chlorine_dosing (Coil 2)...

--- Values AFTER attack ---
pump_running      : False
high_pressure_alarm : False
chlorine_dosing   : False
system_pressure   : 40 PSI

=== Attack complete. No authentication was required. ===
Pump stopped. Chlorine dosing disabled.
Check Scada-LTS - values should now show 0.
PS C:\Users\DV\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security>
```



Business Impact

A successful write attack stops water supply to elevated residential areas, disables chlorination allowing untreated water to enter the distribution network, and masks safety alarms from operators who would otherwise be alerted to the problem. The time between attack execution and operator awareness depends entirely on how frequently operators check the SCADA dashboard and whether any automated alerting is configured. In the lab demonstration, all four process values changed to zero within two seconds of the attack script running.

5.3 IEC 62443 Gap Analysis

Reference	Security Requirement	Gap Identified	Severity
SR 1.1	Identification and Authentication	No authentication on Modbus TCP. Any device can connect and issue commands without credentials.	Critical
SR 4.1	Information Confidentiality	All process data transmitted in cleartext. Traffic is visible to any device on the network segment.	High
SR 5.1	Network Segmentation	Port 502 accessible from any network device before controls were applied. No segmentation existed.	Critical
SR 3.5	Input Validation	All Modbus function codes accepted from any source. Write commands from unknown sources executed immediately.	High
SR 6.1	Audit Log Accessibility	No logging of connection attempts to port 502 before controls were applied. No forensic trail existed.	Medium

6. Risk Register

The following risk register documents all identified risks, their likelihood and impact ratings, and the current status following implementation of compensating controls. Residual risks are those that remain after controls have been applied and require further action or acceptance by the asset owner.

Risk ID	Risk Description	Likelihood	Impact	Inherent Risk	Control Applied	Residual Risk
R-001	Any network-connected device reads live process data from PLC via unauthenticated Modbus TCP	High	High	Critical	C-001 - IP allowlist restricts port 502 access	Medium - IP spoofing remains a theoretical bypass
R-002	Attacker sends write commands to stop pump or disable chlorination via unauthenticated Modbus TCP	High	Critical	Critical	C-001 and C-002 - IP allowlist and function code filter	Low - Both IP and function code must be bypassed
R-003	Attacker performs reconnaissance of process state with no detection	High	High	Critical	C-003 - Audit logging of all blocked attempts	Medium - Only blocked attempts are logged, not successful SCADA reads
R-004	Firewall rules are lost on container restart, restoring unauthenticated access	Medium	Critical	High	Procedural control - rules must be reapplied after restart	High - No persistent firewall configuration in current setup
R-005	Attacker bypasses proxy by connecting directly to port 502 from an IP not matching the allowlist	Low	Critical	High	C-001 - IP allowlist blocks non-authorized IPs on port 502	Low - Requires IP spoofing capability
R-006	Modbus TCP traffic intercepted and analysed on the network segment	Medium	High	High	No control applied	High - Cleartext transmission remains unaddressed
R-007	Insider threat uses authorised SCADA access to issue disruptive write commands	Low	Critical	High	No control applied in this assessment	High - SCADA user authentication and role-based access required

7. Mitigations Implemented

Three compensating controls were implemented following the defence-in-depth principle required by IEC 62443. No single control is sufficient on its own. Together they eliminate the primary attack surface demonstrated in Section 5, while maintaining operational continuity for the authorised SCADA connection.

7.1 Control 1 - IP Allowlist Firewall (IEC 62443 SR 5.1)

Field	Detail
Control ID	C-001
Type	Network access control - host-based firewall
IEC 62443 Requirement	SR 5.1 - Network Segmentation
Implementation	iptables rules applied inside the OpenPLC Docker container
Status	Implemented and verified

iptables rules were applied inside the OpenPLC container to restrict port 502 access to the authorised Scada-LTS IP address only. Rules are processed from top to bottom. Scada-LTS at IP address 172.18.0.4 matches Rule 1 and is permitted through. Any other source reaches Rule 4 and is silently dropped with no response sent back to the requester.

```
# Rule 1: Allow authorised SCADA/HMI only
iptables -A INPUT -p tcp --dport 502 -s 172.18.0.4 -j ACCEPT

# Rule 2: Allow localhost (internal PLC functions)
iptables -A INPUT -p tcp --dport 502 -s 127.0.0.1 -j ACCEPT

# Rule 3: Log all other connection attempts (feeds Control 3)
iptables -I INPUT 3 -p tcp --dport 502 -j LOG --log-prefix 'MODBUS-BLOCKED: '

# Rule 4: Drop all other traffic silently
iptables -A INPUT -p tcp --dport 502 -j DROP
```

```
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -s 172.18.0.4 -j ACCEPT
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -s 127.0.0.1 -j ACCEPT
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -j DROP
root@411fed423857:~/OpenPLC_v3# iptables -L INPUT -n -v
Chain INPUT (policy ACCEPT 1 packets, 52 bytes)
 pkts bytes target     prot opt in     out     source            destination
    0    0 ACCEPT    tcp  --  *      *       172.18.0.4        0.0.0.0/0         tcp dpt:502
    0    0 ACCEPT    tcp  --  *      *       127.0.0.1         0.0.0.0/0         tcp dpt:502
    8  480 DROP      tcp  --  *      *       0.0.0.0/0         0.0.0.0/0         tcp dpt:502
root@411fed423857:~/OpenPLC_v3# |
```

7.2 Control 2 - Modbus Function Code Filter (IEC 62443 SR 3.5)

Field	Detail
Control ID	C-002
Type	Protocol-aware deep packet inspection proxy
IEC 62443 Requirement	SR 3.5 - Input Validation
Implementation	Custom Python proxy deployed on port 5020
Status	Implemented and verified

A Python proxy was deployed on port 5020. The proxy sits between clients and the PLC, extracts the Modbus function code from byte 7 of each MBAP frame, and applies the following policy: read function codes (FC 01 to 04) are permitted from any source; write function codes (FC 05, 06, 15, and 16) are blocked from any source that is not the authorised HMI IP address. Every blocked attempt is logged with the source IP address, timestamp, and function code. This approach mirrors the capability of commercial OT deep packet inspection products including Claroty, Tofino, Dragos, and Nozomi Networks Guardian.

Function Code	Operation	From Authorised HMI	From Other Sources
FC 01, 02, 03, 04	Read operations	Allowed	Allowed
FC 05 - Write Single Coil	Write single Boolean value	Allowed	Blocked and logged
FC 06 - Write Single Register	Write single integer value	Allowed	Blocked and logged
FC 15 - Write Multiple Coils	Write multiple Boolean values	Allowed	Blocked and logged
FC 16 - Write Multiple Registers	Write multiple integer values	Allowed	Blocked and logged

<pre> 1 0 0 ACCEPT tcp -- * * 172.18.0.4 0.0 0.0/0 tcp dpt:502 2 0 0 ACCEPT tcp -- * * 127.0.0.1 0.0 0.0/0 tcp dpt:502 PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> docker exec openplc iptables -A INPUT -p tcp --dport 502 -j LO G --log-prefix "MODBUS-BLOCKED: " --log-level 4 PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> docker exec openplc iptables -A INPUT -p tcp --dport 502 -j DR OP PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> cd "C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projec ts\Modbus Protocol security" PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> python modbus_proxy.py ===== OT SECURITY CONTROL - Modbus TCP Function Code Filter IEC 62443 SR 3.5 - Deep Packet Inspection Proxy ===== 2026-07-23 12:23:41 [INFO] Proxy listening on port 5020 2026-07-23 12:23:41 [INFO] Forwarding allowed traffic to PLC at 127.0.0.1:5 02 2026-07-23 12:23:41 [INFO] Authorised HMI (write-permitted): 172.18.0.4 2026-07-23 12:23:41 [INFO] Write FCs blocked from unauth sources: [5, 6, 15 , 16, 22, 23] 2026-07-23 12:23:41 [INFO] Read FCs allowed from all sources: [1, 2, 3, 4] ===== 2026-07-23 12:26:07 [INFO] New connection from 127.0.0.1:49291 2026-07-23 12:26:07 [INFO] Proxy connection established to PLC at 127.0.0.1 :502 2026-07-23 12:26:07 [BLOCK] FC05 (Write Single Coil) from UNAUTHORISED 127.0 .0.1 → BLOCKED IEC 62443 SR 3.5 2026-07-23 12:26:10 [BLOCK] FC05 (Write Single Coil) from UNAUTHORISED 127.0 .0.1 → BLOCKED IEC 62443 SR 3.5 2026-07-23 12:26:13 [BLOCK] FC05 (Write Single Coil) from UNAUTHORISED 127.0 .0.1 → BLOCKED IEC 62443 SR 3.5 2026-07-23 12:26:17 [BLOCK] FC05 (Write Single Coil) from UNAUTHORISED 127.0 .0.1 → BLOCKED IEC 62443 SR 3.5 2026-07-23 12:26:20 [INFO] Client 127.0.0.1 disconnected </pre>	<pre> Windows PowerShell Copyright (C) Microsoft Corporation. All rights reserved. Install the latest PowerShell for new features and improvements! https://aka .ms/PSWindows PS C:\Users\DVaus> cd "C:\Users\DVaus\OneDrive\Desktop\OT security pathway\P rojects\Modbus Protocol security" PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> python modbus_write_proxy.py === Proxy Retest: Write via port 5020 === Testing if proxy blocks write commands from unauthorised source Attempting to write FALSE to pump_running via proxy... No response received after 3 retries, continue with next request Traceback (most recent call last): File "C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security\modbus_write_proxy.py", line 12, in <module> result = client.write_coil(0, False) ~~~~~^~~~~~ File "C:\Users\DVaus\AppData\Local\Packages\PythonSoftwareFoundation.Pytho n.3.12.qbz5n2kfra8p0\LocalCache\local-packages\Python312\site-packages\pymod bus\client\wixin.py", line 191, in write_coil return self.execute(no_response_expected, pdu) ~~~~~^~~~~~ File "C:\Users\DVaus\AppData\Local\Packages\PythonSoftwareFoundation.Pytho n.3.12.qbz5n2kfra8p0\LocalCache\local-packages\Python312\site-packages\pymod bus\client\base.py", line 189, in execute return self.transaction.sync_execute(no_response_expected, request) ~~~~~^~~~~~ File "C:\Users\DVaus\AppData\Local\Packages\PythonSoftwareFoundation.Pytho n.3.12.qbz5n2kfra8p0\LocalCache\local-packages\Python312\site-packages\pymod bus\transaction\transaction.py", line 160, in sync_execute raise ModbusIOException(txt) pymodbus.exceptions.ModbusIOException: Modbus Error: [Input/Output] No respo nse received after 3 retries, continue with next request PS C:\Users\DVaus\OneDrive\Desktop\OT security pathway\Projects\Modbus Proto col security> </pre>
--	---

7.3 Control 3 - Audit Logging (IEC 62443 SR 6.1)

Field	Detail
Control ID	C-003
Type	Security audit logging
IEC 62443 Requirement	SR 6.1 - Audit Log Accessibility
Implementation	iptables LOG rule inserted before DROP rule in OpenPLC container
Status	Implemented and verified

An iptables LOG rule was inserted at position 3 in the INPUT chain, before the DROP rule. Every connection attempt to port 502 that does not match the authorised sources is written to the system log with the prefix MODBUS-BLOCKED, along with the source IP address, destination port, protocol, and timestamp. In a production environment these log entries would be forwarded to a SIEM platform

such as Splunk for real-time alerting and forensic investigation. This logging capability is also the mechanism that supports the SOCI Act 12-hour incident reporting obligation by providing a timestamped record of when an incident began.

```
# View all blocked Modbus attempts:
docker exec openplc dmesg | grep 'MODBUS-BLOCKED'

# Sample log entry format:
MODBUS-BLOCKED: IN=eth0 SRC=192.168.1.45 DST=172.18.0.2
PROTO=TCP SPT=54231 DPT=502 LEN=66
```

8. Remediation Roadmap and Retest Results

8.1 Remediation Roadmap

The following table lists all recommended remediation actions in priority order. Controls C-001 to C-003 were implemented and verified during this assessment. Recommendations R-004 to R-006 represent additional hardening steps for a production environment and are provided for planning purposes.

ID	Recommendation	IEC 62443	Priority	Effort	Status
R-001	Restrict port 502 to authorised SCADA/HMI IP addresses only using a host-based or network firewall	SR 5.1	Immediate	Low	Implemented
R-002	Deploy a Modbus function code filter to block write commands from non-authorised sources	SR 3.5	Immediate	Medium	Implemented
R-003	Enable audit logging of all port 502 connection attempts and forward logs to a centralised SIEM	SR 6.1	Short term	Low	Partially implemented
R-004	Make iptables rules persistent across container restarts using a startup script or container entry point	SR 5.1	Short term	Low	Not implemented
R-005	Deploy passive OT network monitoring to baseline normal Modbus communication and alert on anomalies	SR 6.2	Short term	High	Not implemented
R-006	Upgrade to Modbus TCP Security (RFC 8600) or replace with DNP3 Secure Authentication where hardware supports it	SR 1.1	Medium term	High	Not implemented
R-007	Tunnel Modbus traffic over IPsec VPN between PLC and SCADA to prevent cleartext exposure	SR 4.1	Medium term	Medium	Not implemented

8.2 Retest Results

All attack scenarios were retested after implementing Controls C-001 to C-003. The following table summarises the results:

Test Case	Before Controls	After Controls	Result
Unauthenticated read via port 502	All 4 values returned with no credentials	ModbusIOException after 3 retries. No data returned.	Blocked
Unauthenticated write via port 502	Pump stopped, chlorination disabled in 2 seconds	ModbusIOException after 3 retries. No write executed.	Blocked

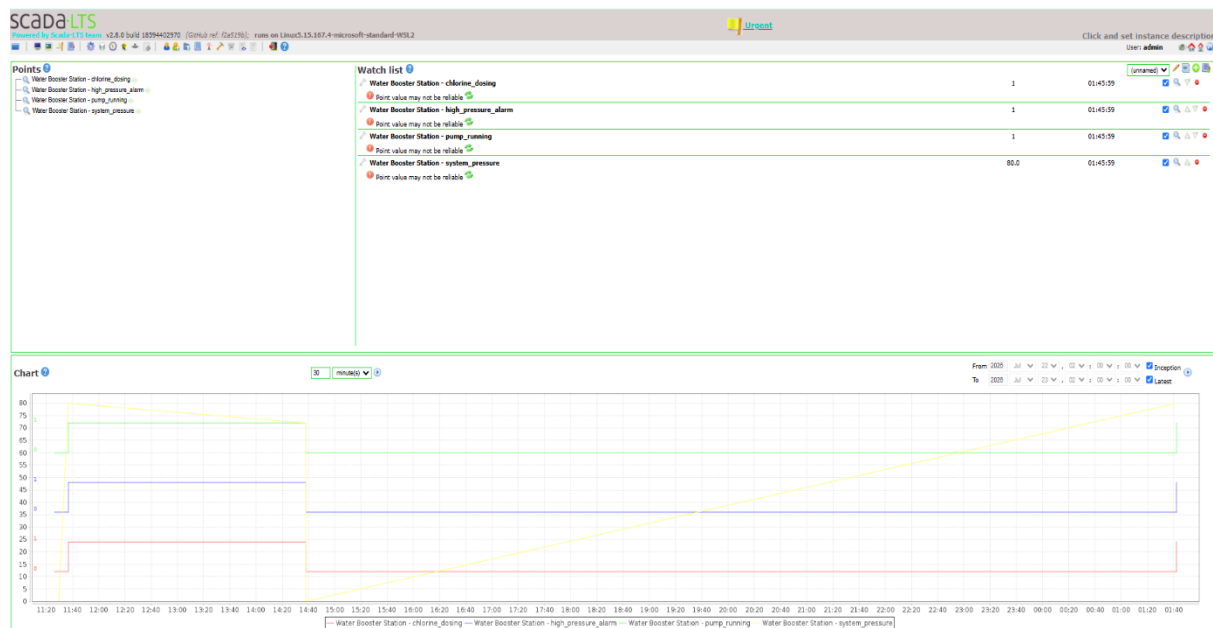
Test Case	Before Controls	After Controls	Result
Write FC05 via proxy port 5020	Not applicable	Proxy logged BLOCKED FC05 from UNAUTHORISED source	Blocked
Authorised Scada-LTS HMI operation	Working normally	Working normally. No disruption to SCADA polling.	Maintained
Blocked attempts logged	No logging in place	All blocked attempts logged with MODBUS-BLOCKED prefix	Confirmed

```
PS C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_read.py
=== OT Security Lab: Unauthenticated Modbus Read ===
Connecting to OpenPLC at 127.0.0.1:502...
No username. No password. No credentials of any kind.

No response received after 3 retries, continue with next request
Traceback (most recent call last):
  File "C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security\modbus_read.py", line 13,
in <module>
    coils = client.read_coils(0, count=3)
             ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\mixins.py", line 78, in read_coils
    return self.execute(
           ^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\base.py", line 189, in execute
    return self.transaction.sync_execute(no_response_expected, request)
           ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\transaction\transaction.py", line 160, in sync_execute
    raise ModbusIOException(txt)
pymodbus.exceptions.ModbusIOException: Modbus Error: [Input/Output] No response received after 3 retries, continue with
next request
```

```
PS C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_write.py
=== OT Security Lab: Unauthenticated Modbus WRITE ===
Simulating CyberAv3ngers attack on Water Booster Station
Target: OpenPLC at 127.0.0.1:502
Credentials required: NONE

--- Current values BEFORE attack ---
No response received after 3 retries, continue with next request
Traceback (most recent call last):
  File "C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security\modbus_write.py", line 15,
in <module>
    coils = client.read_coils(0, count=3)
             ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\mixins.py", line 78, in read_coils
    return self.execute(
           ^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\base.py", line 189, in execute
    return self.transaction.sync_execute(no_response_expected, request)
           ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\transaction\transaction.py", line 160, in sync_execute
    raise ModbusIOException(txt)
pymodbus.exceptions.ModbusIOException: Modbus Error: [Input/Output] No response received after 3 retries, continue with
next request
```



9. Conclusion

This assessment confirmed that the Modbus TCP protocol presents critical security risks in its default configuration. The complete absence of authentication and encryption means that any device with network access to port 502 can read live process data and issue arbitrary control commands. This vulnerability directly mirrors the conditions exploited in the 2023 CyberAv3ngers attack on US water treatment infrastructure and remains present in operational facilities worldwide where Modbus has not been supplemented with compensating controls.

Three layered compensating controls were implemented and verified as effective. The IP allowlist firewall blocked all unauthorised port 502 connections at the network layer. The Modbus function code filter prevented write commands from non-authorised sources at the protocol layer. The audit logging rule created a forensic trail of every blocked attempt that would support incident investigation and SOCI Act reporting obligations in a production environment. Critically, all three controls were implemented without disrupting the authorised Scada-LTS SCADA connection, demonstrating that security improvements can be applied without impacting industrial operations.

Three recommendations in the remediation roadmap remain unimplemented and represent residual risk. Of these, making the iptables rules persistent across container restarts is the most urgent because the current implementation requires manual reapplication after every restart. Passive OT network monitoring would provide ongoing detection capability for attack patterns that bypass perimeter controls. Protocol-level authentication through Modbus TCP Security or a replacement protocol addresses the root cause but requires hardware support and longer-term planning.

Prepared by:

Deepak Varma

OT/ICS Security Portfolio Project

July 2026